

Stack 06 consolidated local audit and SOP retrospective

Reviewer: Codex /root, keepkey-vault-v11-agent-1. Completed UTC: 2026-09-24T20:50:01.370830+00:00.

Decision and immutable identity

Local source and software audit: complete, with no newly confirmed in-scope firmware defect outstanding after this pass. One verification gap and one coordination-status defect were found and corrected below. This is local acceptance against the completed immediate Stack 05 predecessor; it is not assembled-release or physical-device acceptance. No Copilot request was sent in this pass.

Firmware PR #859: base 5c3f2d927f56a8646178d00c0abc9ed01c427393; head efdeb678bc33c616cf8048fb5773548f0da96fa7; implementation 7d76cd47c2c3f50905224b32402e9e5e815e526c. Firmware branch audit/715-stack06-agent1-reconcile remains unchanged and clean. Historical PR #836 is not the reviewed candidate. Live GitHub identities and CI were rechecked. CI 35982066194 passed every required job on this exact head. Completed Stack 05 is PR #858; older Stack 04/03 propagation remains a separate integration gate.

The SOP and this supplementary receipt live on audit/715-review-preflight-20260924, descended from the frozen firmware head. They do not change firmware, tests, pins, build or CI configuration. Passing firmware evidence is retained with this explicit impact assessment; no redundant matrix is dispatched for documentation. The canonical main-worktree SOP is updated from a hash-checked snapshot. Its prior hash is preserved in the evidence directory; the prior SOP is committed before the revision on this documentation branch. The untracked main ledger remains coordination evidence, not a claimed committed handoff.

Why previous paid reviews were inefficient

Miss	Root cause	Local prevention now applied
Removed domain guards, legacy policy behavior and 16 Ethereum tests	Replay reviewed mainly through passing totals and newly added code	Read removed lines, compare predecessor tests and inspect assertion changes, trace migrations by known policy name
Native-value unlimited approval bypass, then split/trailing equivalents	Display classifier was treated as a security boundary; initial fix tested one representation	Follow actual signing entry through specialized and generic paths; retain native-value, padded-zero, split 1/2/3/4/16/67 and trailing-data counterexamples plus valid unrelated streaming
CoinTable 24 to 8 regression	Firmware advertised capacity was tested without a caller-default inventory	Trace bundled HDWallet default 10-entry request; restored 24 and checked 10/24 wire responses plus full/BTC RAM
Repeated requests and stale status prose	External freshness was treated as a next-step requirement despite the SOP's local-acceptance rule; current status was scattered across appended history	Make policy precedence explicit; no automatic corrective request; stable source/PDF plus one current ledger summary; historical review stays historical

The three delivered review IDs remain 5299708246, 5300506855 and 5302461413. The third says Findings: None, zero inline findings, but its body CoinTable concern led to a repair. It covers ff956077f, not this final head. All six earlier threads have dispositions and are resolved. A fresh paid review may add independent scrutiny at an owner-selected external checkpoint; it is not needed merely to refresh a badge or documentation, and none is proposed as an automatic next step.

Findings from this local pass

ID	Finding and disposition	Evidence
S06-LA-01	Three existing Uniswap liquidity host tests were skipped by broad later-capability flags despite changes to their owned paths. Verification gap closed locally with a narrow, unchanged-module run and explicit empty capability list. No firmware change needed.	liquidity-host.xml/log: 3 passed, zero skips; add-liquidity fixed signature, unlimited approval refusal, different-recipient removal refusal. The broad 178/484 skip totals remain historical and unchanged; these three are separately closed for this candidate. Repeat this narrow module on future changes to these paths.
S06-LA-02	The canonical top-level Stack 06 ledger row/claim still named ff956077f and two reviews while appended history had efdeb678b and three. Current summary corrected; prior receipts retained as history.	Canonical main ledger and claim, with this immutable receipt pointer. No firmware verification affected.

S06-LA-03	SOP wording mixed local acceptance and external current-head completion, encouraging repeated authorization prompts. Policy precedence and consolidated local preflight clarified.	Revised REHEARSAL-SOP.md; no automatic corrective allowance, consumer/deletion/representation/skip checks, bounded stop condition and evidence carry-forward.
-----------	--	---

Source review and counterexamples

Reviewed every adjacent source, test, build, dependency and evidence path listed below; compared against the immediate predecessor and inspected retained callers. The changed EIP-712 helpers are not a production structured-signing qualification: the real FSM gate returns a failure before parsing, `ethereum_structured_eip712_enabled` stays false, and its regression executes. Full canonical EIP-712 support and a complete JSON-parser safety proof remain outside this unit; no enablement follows from helper tests.

Transport: dispatcher authorization hooks execute before normal handlers; cleanup executes after parsed handlers and on parse failures. Firmware supplies strong hooks; board-only weak defaults preserve linkage. Cross-workflow acknowledgments, protected Ping, recovery replacement and derived scratch cleanup execute in the full/BTC variants where applicable. Main/debug callback tests use actual callback bodies with mocked driver reads; physical controller behavior remains unverified.

Trust/storage: match `AdvancedMode` by compiled identity; preserve only known legacy `ShapeShift` preference; clear stale persisted bit 12 and revoke runtime signers on lock/disable. Soft Initialize intentionally retains the policy while discarding signers. Full/BTC upgrade/read/write checks and separately owned reboot evidence cover this contract. Runtime metadata remains additive to amount/calldata/fee screens and bound to the signed transaction; unchanged `signed_metadata` implementation has no compiled trusted slots.

Signing/display: liquidity validates mainnet identities, canonical ABI addresses, exact lengths, known token units and 64-bit deadline before specialized review. Derivation failures wipe root/partial node; successful recipient derivation wipes before display. Unknown shapes use retained fallback gates; malformed specialized confirmation refuses. Unlimited standard ERC20 approval is refused before generic confirmation irrespective of native value, trailing data or possible split approval prefix. This is a selector/ABI policy, not a proof of arbitrary smart-contract semantics. Valid unrelated Ethereum streaming continues to renew its deadline.

Ripple/display: complete memo paging and independent 191/192/193/199 wire-prefix assertions preserve signed bytes; retained 199-byte tail OLED capture supports paging. Exact-byte display tests cover all 256 bytes and a trailing marker. CoinTable generated bound now equals predecessor 24; bundled HDWallet start+10 default is compatible. Full protocol 10/24 and BTC two-entry responses were decoded, and the native negative control fails on old capacity 8.

Evidence checked and carried forward

Check	Result and scope
Test identity inventory	506 predecessor declarations, 550 current; none removed. All 44 added declarations execute in full; eight execute in BTC, with 36 altcoin-specific exclusions listed in <code>test-preservation.json</code> . Declaration counts include other test binaries; they are not firmware-unit execution totals. Assertion diffs were inspected separately.
Host source identity	All 260 tracked files/symlinks match <code>b745562be6a13cc83b2a547d7ef86637f4556dbb</code> . Compared Git blob contents; symlinks compared by target text. Net host diff is only Ripple test oracle/boundaries.
Existing validation bundle	All 1,064 archived files match the committed SHA256 manifest; none missing. Two external ARM identities remain outside the archive as labeled.
New targeted execution	Three previously skipped liquidity host tests pass on the current full emulator; no assertion or host source changed.
Current firmware validation	Full native 489/19/18, BTC 135/19/18; full host 653 pass/178 skip, BTC 347 pass/484 skip; both ARM/resource gates pass. Exact-head hosted run 35982066194 repeats required ARM/emulator/native/host/OLED and final report/evidence gates.
Retained adversarial evidence	Removed key/tiny wipes, metadata suppression, strict domain guard and allowance/CoinTable rollback controls fail as expected. No new code invalidates those controls.

Report and status	All 52 adjacent paths/counts match the existing inspected eight-page source/PDF; no new firmware report commit made. This supplemental audit has its own source/PDF and does not rewrite historical review outcomes.
-------------------	--

Reproduction: git diff --name-status

5c3f2d927f56a8646178d00c0abc9ed01c427393..efdeb678bc33c616cf8048fb5773548f0da96fa7; git diff --numstat 5c3f2d927f56a8646178d00c0abc9ed01c427393..efdeb678bc33c616cf8048fb5773548f0da96fa7. Test inventory extracts TEST/TEST_F/TEST_P identities from both immutable trees and compares to current native XML, with assertion review performed separately. The liquidity runner and its raw XML/log are attached. Exact firmware CI: <https://github.com/BitHighlander/keepkey-firmware/actions/runs/35982066194>.

Complete adjacent-path review inventory

Counts below describe the frozen firmware PR, not this separate documentation delta. Binary counts are dashes; tests/docs and dependency pointer lines are included. No sum of historical commits is presented as net change.

Path	Added / deleted	Review disposition
.github/workflows/ci.yml	4 / 1	CI/skip inventory and real USB callback harness; exact-head CI passes
.gitmodules	1 / 1	Fetchable host fork; immutable pin checked
deps/python-keepkey	1 / 1	Only Ripple oracle/boundaries change; 260 tracked host files match pin
docs/release/audit-units/715-06-evidence-sha256-20260924.txt	20 / 0	Historical/current report distinction, exact inventory and evidence hashes checked; existing eight-page PDF inspected
docs/release/audit-units/715-06-history-20260924.tsv	82 / 0	Historical/current report distinction, exact inventory and evidence hashes checked; existing eight-page PDF inspected
docs/release/audit-units/715-06-intake-evidence-20260924.tgz	- / -	Historical/current report distinction, exact inventory and evidence hashes checked; existing eight-page PDF inspected
docs/release/audit-units/715-06-reconciliation-20260924.md	140 / 0	Historical/current report distinction, exact inventory and evidence hashes checked; existing eight-page PDF inspected
docs/release/audit-units/715-06-review-20260924.md	185 / 0	Historical/current report distinction, exact inventory and evidence hashes checked; existing eight-page PDF inspected
docs/release/audit-units/715-06-review-20260924.pdf	- / -	Historical/current report distinction, exact inventory and evidence hashes checked; existing eight-page PDF inspected
docs/release/audit-units/715-06-skips-20260924.tsv	663 / 0	Historical/current report distinction, exact inventory and evidence hashes checked; existing eight-page PDF inspected
docs/release/audit-units/715-06-validation-20260924.tgz	- / -	Historical/current report distinction, exact inventory and evidence hashes checked; existing eight-page PDF inspected
docs/release/audit-units/715-06-validation-sha256-20260924.txt	1086 / 0	Historical/current report distinction, exact inventory and evidence hashes checked; existing eight-page PDF inspected
docs/security/evidence/rom-printf-integer-percent/01-thorchain-withdraw-25.05pct.png	- / -	Historical/current report distinction, exact inventory and evidence hashes checked; existing eight-page PDF inspected
docs/security/evidence/rom-printf-integer-percent/02-thorchain-sending-eth.png	- / -	Historical/current report distinction, exact inventory and evidence hashes checked; existing eight-page PDF inspected
docs/security/evidence/rom-printf-integer-percent/README.md	17 / 0	Historical/current report distinction, exact inventory and evidence hashes checked; existing eight-page PDF inspected

include/keepkey/firmware/eip712.h	8 / 4	Interface/declaration/comment reconciliation checked against definitions and consumers; full/ BTC builds
include/keepkey/firmware/ethereum.h	1 / 0	Interface/declaration/comment reconciliation checked against definitions and consumers; full/ BTC builds
include/keepkey/firmware/ethereum_contracts/thortx.h	13 / 11	Interface/declaration/comment reconciliation checked against definitions and consumers; full/ BTC builds
include/keepkey/firmware/ethereum_contracts/zxliquidtx.h	4 / 4	Interface/declaration/comment reconciliation checked against definitions and consumers; full/ BTC builds
include/keepkey/firmware/thorchain.h	2 / 6	Interface/declaration/comment reconciliation checked against definitions and consumers; full/ BTC builds
include/keepkey/firmware/tiny-json.h	0 / 6	Interface/declaration/comment reconciliation checked against definitions and consumers; full/ BTC builds
lib/board/draw.c	1 / 1	Comment-only: persistence wording reconciled with session cache
lib/board/messages.c	19 / 3	Before/after dispatch hooks; actual native dispatch and secret-cleanup assertions
lib/firmware/CMakeLists.txt	0 / 1	Removes duplicate signed_metadata entry; full/ BTC ARM and native links pass
lib/firmware/eip712.c	377 / 285	Bounds/types/domain validation, cancel and stale-state cleanup; parser remains wire-disabled
lib/firmware/ethereum.c	64 / 10	Allowance guard before all classifiers; equivalent inputs, unrelated streaming, metadata additive binding
lib/firmware/ethereum_contracts.c	1 / 1	Liquidity callback signature; specialized/fallback extent checks retained
lib/firmware/ethereum_contracts/zxapliquid.c	110 / 96	Canonical chain/pair/spender/value/extent; amount rendering; native tests and host refusal
lib/firmware/ethereum_contracts/zxliquidtx.c	160 / 190	ABI bounds, LP units, recipient derivation/wipe, deadline; native checks and three unskipped host tests
lib/firmware/fsm_msg_common.h	10 / 0	Protected Ping aborts old signing; GetCoinTable restored predecessor capacity checked separately
lib/firmware/fsm_msg_eos.h	6 / 0	Only validated nonempty or zero-length-completed action progress renews; native progress tests
lib/firmware/fsm_msg_ethereum.h	8 / 1	AdvancedMode metadata boundary; structured EIP-712 gate remains false
lib/firmware/fsm_msg_ripple.h	15 / 8	Full memo paging; cancellation wipes; native/ host prefix and retained OLED tail evidence
lib/firmware/recovery_cipher.c	2 / 0	Accepted edit/delete progress only; empty delete and polling do not renew
lib/firmware/ripple.c	1 / 1	Inclusive length 192 boundary; independent native/host 191/192/193/199 vectors
lib/firmware/signing.c	19 / 13	Valid stage requests renew deadline; invalid ack/polling and expiry tests retained
lib/firmware/storage.c	26 / 12	RAM-only AdvancedMode, legacy name allowlist, flash bit scrub, signer revocation; full/ BTC native and reboot evidence

scripts/emulator/capture-thor-percent.py	99 / 0	Historical capture utility; unchanged firmware percent implementation not credited as new code
scripts/emulator/python-keepkey-tests.sh	11 / 0	Three scoped contract modules bypass unrelated later skips; liquidity supplemental run closes fourth-module gap
scripts/tests/test_usb_receive_callbacks.py	85 / 0	Production callback bodies exercised; driver mocked, physical USB explicitly excluded
unittests/firmware/CMakeLists.txt	4 / 0	Assertion/build-registration diff inspected; predecessor declaration inventory and full/BTC XML reconciled
unittests/firmware/app_confirm.cpp	48 / 0	Assertion/build-registration diff inspected; predecessor declaration inventory and full/BTC XML reconciled
unittests/firmware/eip712.cpp	194 / 0	Assertion/build-registration diff inspected; predecessor declaration inventory and full/BTC XML reconciled
unittests/firmware/ethereum.cpp	217 / 0	Assertion/build-registration diff inspected; predecessor declaration inventory and full/BTC XML reconciled
unittests/firmware/fsm.cpp	126 / 20	Assertion/build-registration diff inspected; predecessor declaration inventory and full/BTC XML reconciled
unittests/firmware/kkconfirm_driver.h	20 / 0	Assertion/build-registration diff inspected; predecessor declaration inventory and full/BTC XML reconciled
unittests/firmware/liquidity_key_probe.c	54 / 0	Assertion/build-registration diff inspected; predecessor declaration inventory and full/BTC XML reconciled
unittests/firmware/messages_probe.c	11 / 0	Assertion/build-registration diff inspected; predecessor declaration inventory and full/BTC XML reconciled
unittests/firmware/ripple.cpp	17 / 0	Assertion/build-registration diff inspected; predecessor declaration inventory and full/BTC XML reconciled
unittests/firmware/signed_metadata.cpp	264 / 7	Assertion/build-registration diff inspected; predecessor declaration inventory and full/BTC XML reconciled
unittests/firmware/storage.cpp	98 / 28	Assertion/build-registration diff inspected; predecessor declaration inventory and full/BTC XML reconciled
unittests/firmware/usb_rx.cpp	74 / 0	Assertion/build-registration diff inspected; predecessor declaration inventory and full/BTC XML reconciled

Remaining boundaries and next action

No known in-scope source defect remains open from this consolidated pass. Internal Stack 06 source/software acceptance is recorded at the frozen head. Independent review cannot guarantee absence of undiscovered defects. Physical USB/OLED/ buttons, signed-device upgrade, earlier predecessor propagation into the complete assembled release and release promotion remain separate. Agent 2 retains Stack 07 and agent 3 retains 00b; this pass changes neither claim nor branch. Any later material source/pin/configuration change reopens the affected properties and interactions, with exact checks selected from its impact. No new Copilot request is issued or queued.